# EburSeal

Le sceau invisible des diplômes ivoiriens

## Cahier des charges

Application PWA/SPA — Jakarta EE 11 · WildFly 42 · Java 25

| | |
|---|---|
| **Projet** | EburSeal — plateforme de délivrance et de vérification de diplômes infalsifiables (Côte d'Ivoire) |
| **Équipe (binôme)** | OUATTARA Yacouba · YEO Tanna Daouda |
| **Formation** | SUP'COM — 3e année cycle ingénieur, option Cybersecurity and Defense (CySeD) |
| **Module / encadrant** | Sécurité Applicative — Dr. Ing. Mohamed-Becha Kaâniche |
| **Document compagnon** | Recueil des besoins fonctionnels et de sécurité (SRE) — docs/recueil-des-besoins.pdf |
| **Version / date** | v1.0 — 08/11/2026 |

### Historique des versions

| Version | Date | Auteur(s) | Modifications |
|---|---|---|---|
| **1.0** | 08/11/2026 | O. Yacouba, Y. T. Daouda | Version initiale remise à la séance 2 (spécification & conception) |

# Sommaire

**1. Présentation du projet 3**
1.1 Cadre de l'atelier . . . 3
1.2 Équipe . . . 3
**2. Contexte et problématique 3**
2.1 Le problème : la confiance dans les diplômes . . . 3
2.2 Les trois techniques, et pourquoi elles sont complémentaires . . . 4
**3. Objectifs 4**
3.1 Objectifs métier . . . 4
3.2 Objectifs de sécurité (repris de l'énoncé) . . . 4
**4. Périmètre 4**
4.1 Inclus dans le projet . . . 5
4.2 Proportionnalité au binôme . . . 5
4.3 Exclu du périmètre . . . 5
**5. Acteurs et rôles 6**
**6. Description fonctionnelle 6**
6.1 Scénario nominal : de l'émission à la vérification . . . 9
**7. Exigences non fonctionnelles (hors sécurité) 9**
**8. Contraintes techniques et architecture 9**
8.1 Socle technique . . . 9
8.2 Architecture cible . . . 10
8.3 Principales ressources de l'API REST . . . 10
**9. Démarche de sécurité et feuille de route 11**
**10. Organisation, livrables et planning 11**
10.1 Organisation du dépôt GitHub . . . 11
10.2 Livrables . . . 11
10.3 Planning prévisionnel . . . 12
**11. Critères d'acceptation et « Definition of Done » 12**
11.1 Risques projet . . . 12

# 1. Présentation du projet

## 1.1 Cadre de l'atelier

Ce cahier des charges est réalisé dans le cadre de l'atelier du module **Sécurité Applicative**. Chaque équipe conçoit puis développe une application **PWA/SPA** dont la partie serveur repose sur **Jakarta EE 11** (serveur **WildFly 42**, **Java 25**). L'énoncé impose trois contraintes :

- le métier doit faire **la part belle aux services de dissimulation de l'information** : stéganographie, watermarking, fingerprinting ;
- le périmètre métier est **proportionnel à l'effectif** de l'équipe, alors que les exigences de sécurité sont **identiques pour toutes les équipes** ;
- les aspects de sécurité **suivent l'agenda du cours** (chapitres 2 à 7) : l'application s'enrichit au fil des séances.

La progression est suivie sur un dépôt **GitHub privé**, partagé avec l'encadrant. Ce document et le recueil des besoins sont déposés en PDF dans le répertoire **docs/**.

## 1.2 Équipe

Le binôme est composé de **OUATTARA Yacouba** et **YEO Tanna Daouda**. Les responsabilités sont **partagées** : chaque membre intervient sur le socle de sécurité, le moteur de dissimulation et l'application cliente. La seule règle d'organisation est la **revue croisée** : aucune contribution n'est fusionnée sans avoir été relue et approuvée par l'autre membre (inspection par les pairs, étape 9 de SQUARE).

# 2. Contexte et problématique

## 2.1 Le problème : la confiance dans les diplômes

En Côte d'Ivoire, la fraude aux diplômes est un problème public et récurrent. En juillet 2025, le tribunal de première instance d'Abidjan-Plateau a condamné 84 agents des Douanes à six mois de prison ferme pour usage de faux documents lors d'un concours professionnel exceptionnel (décision frappée d'appel ; sources : *Fraternité Matin* et *Connectionivoirienne*, 28/07/2025). Des étudiants d'écoles de formation ont été exclus pour la même raison, et les concours de la fonction publique signalent chaque année des candidats porteurs de faux diplômes. Aujourd'hui, vérifier un diplôme suppose de contacter l'établissement émetteur : c'est lent, rarement fait, et impossible à grande échelle.

EburSeal répond à **un seul problème** : **permettre à quiconque de savoir, en quelques secondes, si un diplôme ivoirien est authentique, intact et présenté par son vrai titulaire.** Ce problème recouvre trois fraudes distinctes, et chacune des trois techniques de dissimulation de l'énoncé en traite une :

| Fraude | Exemple | Technique | Ce qu'elle prouve |
|---|---|---|---|
| **Le faux complet** | Diplôme fabriqué de toutes pièces | **Watermarking** : filigrane invisible lié à la clé de l'établissement | **Qui** a émis le diplôme |
| **Le vrai diplôme retouché** | Mention, niveau ou année modifiés sur une copie authentique | **Stéganographie** : les données officielles signées sont cachées dans le document | **Ce qui** a été émis |
| **Le diplôme usurpé** | Copie authentique d'un autre présentée comme la sienne | **Fingerprinting** : chaque copie partagée porte une empreinte propre à son destinataire | **À qui** la copie a été remise |

> **Le nom** — le nom **EburSeal** associe *ebur*, « ivoire » en latin (racine d'« Éburnie », nom poétique de la Côte d'Ivoire), et *seal*, le sceau. Littéralement : **le sceau de l'Ivoire**, un sceau que l'on ne voit pas mais que l'on peut toujours vérifier.

### 2.2 Les trois techniques, et pourquoi elles sont complémentaires

| Critère | Watermarking (filigrane) | Stéganographie (sceau caché) | Fingerprinting (empreinte) |
|---|---|---|---|
| **Ce qui est inséré** | Une marque de l'établissement, identique sur tous ses diplômes | Les données officielles du diplôme, signées et chiffrées | Un code aléatoire différent pour chaque copie |
| **Propriété recherchée** | Robustesse + infalsifiabilité (clé secrète) | Dissimulation + intégrité (signature) | Robustesse + unicité |
| **Ce qu'un fraudeur ignore** | La clé de l'établissement | L'existence et l'emplacement du sceau | Le code de sa copie et sa position |
| **Moteur** | DCT 8×8, blocs réservés à la couche filigrane | DCT 8×8, blocs réservés au sceau | DCT 8×8, blocs réservés à l'empreinte |
| **Question à laquelle elle répond** | « Cet établissement a-t-il émis ce document ? » | « Le contenu a-t-il été modifié ? » | « Cette copie m'était-elle destinée ? » |

**Pourquoi c'est bien de la stéganographie** — dans EburSeal, la stéganographie ne sert pas à cacher une conversation, mais à cacher **l'existence et l'emplacement** d'une preuve. Le sceau est placé à des positions secrètes et chiffré : sans la clé, rien ne le distingue du bruit de l'image (SR-CON-04). C'est bien de la stéganographie au sens du cours : le canal est dissimulé dans un support anodin. Ce qui change, c'est l'usage : le message caché est une **preuve d'intégrité signée**. Un faussaire ne peut ni la retirer proprement (il ne sait pas où elle est), ni la recopier sur un autre diplôme (elle est liée par signature aux données officielles).

Les trois couches partagent **un seul moteur** (transformée en cosinus discrète par blocs 8×8, comme JPEG) mais occupent des **ensembles de blocs disjoints** tirés au sort par une clé secrète. C'est ce qui rend le projet réalisable par un binôme : un seul moteur à maîtriser, trois usages.

## 3. Objectifs

### 3.1 Objectifs métier

| Code | Objectif | Indicateur de réussite |
|---|---|---|
| **OM-1** | Permettre à un établissement validé d'émettre des diplômes infalsifiables | Émission d'un diplôme en moins de 15 s, double validation, certificat signé |
| **OM-2** | Permettre à quiconque de vérifier un diplôme à partir du seul document | Verdict en moins de 10 s ; marques lisibles après JPEG qualité 75 et redimensionnement à 75 % |
| **OM-3** | Détecter les copies présentées hors de leur contexte | Alerte au vérificateur et au titulaire ; zéro fausse accusation sur le banc de test |
| **OM-4** | Offrir une application installable, simple sur mobile | PWA installable ; vérification en 3 écrans maximum |

### 3.2 Objectifs de sécurité (repris de l'énoncé)

| Principe imposé | Traduction dans EburSeal |
|---|---|
| **Shift-Left** | 71 exigences de sécurité rédigées **avant** la première ligne de code métier ; chaque fonctionnalité a ses cas d'abus avant d'être développée |
| **Perspective de l'attaquant** | 11 cas d'abus, 6 profils d'attaquants (faussaire, titulaire fraudeur, imposteur, agent corrompu…), 2 arbres d'attaque, analyse STRIDE |
| **Triptyque C-I-D** | Besoins C-I-D cotés pour chacun des 9 actifs ; l'**intégrité** du registre et des documents est la propriété dominante |
| **Pas de listes génériques** | Exigences chiffrées et propres au métier, ex. « un diplôme n'est émis qu'après validation par un responsable différent du préparateur » plutôt que « contrôler les accès » |

## 4. Périmètre

## 4.1 Inclus dans le projet

| Module | Contenu | Besoins |
|---|---|---|
| **Socle** | Comptes, activation par invitation, MFA, données personnelles | BF-CPT-01 à 05 |
| **Établissement** | Inscription et validation des établissements, gestion des agents | BF-ETB-01, 02 |
| **Émission** | Préparation, double validation, émission unitaire et par lot, révocation | BF-EMI-01 à 04 |
| **Watermarking** | Filigrane invisible de l'établissement, mention visible, certificat d'émission | BF-WM-01 à 03 |
| **Stéganographie** | Sceau caché signé, comparaison affiché/officiel, vérification autoportée | BF-STG-01 à 03 |
| **Fingerprinting** | Copies traçables, copie personnelle, détection hors contexte, gestion des partages | BF-FP-01 à 04 |
| **Vérification** | Vérification publique, espace vérificateur, rapport signé | BF-VER-01 à 03 |
| **Administration / PWA** | Validation des acteurs, quotas, audit ; application installable | BF-ADM-01 à 03, BF-PWA-01, 02 |

## 4.2 Proportionnalité au binôme

Le métier est proportionné à un binôme ; un trinôme irait plus loin sur les points ci-dessous. Les exigences de sécurité restent **complètes**.

| Dimension | Binôme (EburSeal v1) | Trinôme (référence, non retenu) |
|---|---|---|
| **Supports** | Diplômes numériques : PDF d'une page et images (PNG, JPEG) | Idem + diplômes papier imprimés puis photographiés (robustesse impression–numérisation) |
| **Vérification du contenu** | Données officielles du sceau affichées **à côté** du document ; comparaison par le vérificateur | Comparaison automatique par OCR |
| **Fingerprinting** | Code de 64 bits par copie, code correcteur, ≤ 30 partages par diplôme | Codes anti-collusion (Tardos) résistant à la comparaison de plusieurs copies |
| **Établissements** | Clés gérées par la plateforme (coffre chiffré) | Clés détenues par l'établissement (HSM / carte à puce) |
| **Sécurité** | **Ensemble complet des 71 exigences** | **Identique** |

## 4.3 Exclu du périmètre

- diplômes **papier** photographiés : la robustesse à l'impression puis à la photographie relève de la recherche ; elle est reportée ;
- résistance des empreintes à la **collusion** de plusieurs destinataires (limite assumée, cf. SR-DIM-06) ;
- rattachement du compte titulaire à l'identité numérique nationale (NNI) : évolution envisagée après le module ;
- diplômes émis **avant** l'adhésion d'un établissement : seuls les diplômes émis via EburSeal sont vérifiables ;
- vérificateur qui ne vérifie pas : traité par la sensibilisation, pas par l'application.

# 5. Acteurs et rôles

| Acteur | Description | Ce qu'il peut faire |
|---|---|---|
| **Visiteur** | Toute personne, sans compte | **Vérifier publiquement** un diplôme (authenticité, contenu officiel, statut), sans jamais voir le destinataire d'une copie |
| **Titulaire** | Diplômé, invité par son établissement | Consulter son portefeuille de diplômes, télécharger sa copie personnelle, **partager des copies traçables**, voir qui a vérifié ses copies |
| **Agent émetteur** | Personnel de scolarité d'un établissement validé | Saisir un diplôme, déposer son visuel, soumettre à validation |
| **Responsable émetteur** | Directeur des études / scolarité (MFA obligatoire) | **Valider** l'émission préparée par un agent (double validation), révoquer un diplôme |
| **Vérificateur** | Organisation inscrite et validée (employeur, administration, école) | Recevoir des copies partagées, vérifier avec contrôle du destinataire, télécharger un rapport de vérification |
| **Administrateur** | Exploitant de la plateforme (MFA obligatoire) | Valider établissements et vérificateurs, gérer comptes et quotas — **sans pouvoir émettre ni modifier un diplôme** |
| **Auditeur** | Responsable sécurité (MFA obligatoire) | Lecture seule des journaux d'audit, des alertes et de l'état de la chaîne d'intégrité |

La matrice ci-dessous fixe les droits par défaut. Toute case vide est un **refus** (refus par défaut, SR-AUZ-01).

| Fonction | Visit. | Titul. | Agent | Resp. | Vérif. | Admin | Audit. |
|---|---|---|---|---|---|---|---|
| **Vérification publique** | ✔ | ✔ | ✔ | ✔ | ✔ | ✔ | ✔ |
| **Portefeuille, copie personnelle, partages** | | ✔ (les siens) | | | | | |
| **Préparer un diplôme** | | | ✔ (son étab.) | ✔ (son étab.) | | | |
| **Valider / émettre / révoquer** | | | | ✔ (≠ préparateur) | | | |
| **Recevoir des copies, vérifier avec contrôle du destinataire** | | | | | ✔ | | |
| **Valider établissements et vérificateurs, quotas** | | | | | | ✔ (MFA) | |
| **Créer, modifier ou réactiver un diplôme** | | | | | | ✘ | ✘ |
| **Consulter journaux et alertes** | | Son historique | | | | | ✔ lecture (MFA) |
| **Modifier / supprimer un journal** | | | | | | ✘ | ✘ |

# 6. Description fonctionnelle

La liste détaillée des 29 besoins fonctionnels, avec priorités MoSCoW et critères d'acceptation, figure dans le recueil des besoins (§ 3). En voici la synthèse par module.

### Module Socle

Les comptes ne sont pas ouverts librement : un titulaire est **invité** par son établissement, un vérificateur est **validé** par l'administrateur.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-CPT-01** | **Activer un compte** — Le titulaire active son compte depuis l'invitation envoyée par son établissement ; les vérificateurs créent un compte d'organisation soumis à validation. | M |
| **BF-CPT-02** | **Se connecter / se déconnecter** — Authentification par e-mail + mot de passe, puis second facteur si activé ou obligatoire pour le rôle. | M |
| **BF-CPT-03** | **Gérer le second facteur** — Activer un TOTP (application d'authentification) et obtenir des codes de secours. | M |
| **BF-CPT-04** | **Réinitialiser le mot de passe** — Demande par e-mail, lien à usage unique. | M |
| **BF-CPT-05** | **Gérer ses données personnelles** — Le titulaire consulte et exporte ses données, et peut fermer son compte (les diplômes restent au registre de l'établissement). | S |

### Module Établissement

Un établissement n'émet rien tant qu'il n'a pas été validé ; à la validation, la plateforme génère ses clés de filigrane et de signature.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-ETB-01** | **Inscrire un établissement** — Demande d'inscription d'un établissement (pièces justificatives) ; validation par l'administrateur, qui génère ses clés. | M |
| **BF-ETB-02** | **Gérer les agents** — Le responsable émetteur invite, suspend et retire les agents de son établissement. | M |

### Module Émission

L'émission suit le principe des « quatre yeux » : l'agent prépare, un responsable différent valide. C'est la parade principale au diplôme de complaisance.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-EMI-01** | **Préparer un diplôme** — L'agent saisit les données officielles (titulaire, date de naissance, intitulé, spécialité, mention, session, numéro) et dépose le visuel du diplôme (PDF d'une page ou PNG). | M |
| **BF-EMI-02** | **Valider et émettre** — Le responsable relit et valide ; la plateforme applique automatiquement le **filigrane**, le **sceau caché** et produit le **certificat d'émission** ; le titulaire est invité. | M |
| **BF-EMI-03** | **Émettre par lot** — Import d'un fichier CSV + visuels pour une promotion entière, puis validation groupée. | S |
| **BF-EMI-04** | **Révoquer un diplôme** — Le responsable révoque un diplôme (erreur, fraude) avec motif ; une réémission corrigée est possible. | M |

### Module Watermarking

Chaque diplôme émis reçoit le filigrane invisible de son établissement et un certificat d'émission signé.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-WM-01** | **Filigrane de l'établissement** — Filigrane invisible, robuste, lié à la clé secrète de l'établissement, inséré dans le domaine DCT de chaque diplôme émis. | M |
| **BF-WM-02** | **Mention visible** — Mention visible discrète « Vérifiable sur EburSeal » et numéro court du diplôme. | C |
| **BF-WM-03** | **Certificat d'émission** — Certificat signé par l'établissement : empreinte SHA-256 du document, données officielles, date d'émission. | M |

### Module Stéganographie

Le sceau caché transporte les données officielles signées : le document porte sa propre preuve, vérifiable même sans le registre.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-STG-01** | **Sceau caché** — Les données officielles signées sont **dissimulées dans le document lui-même** (domaine DCT, positions secrètes, code correcteur). | M |
| **BF-STG-02** | **Comparer affiché / caché** — À la vérification, les données extraites du sceau sont affichées **à côté** du document pour que le vérificateur compare. | M |
| **BF-STG-03** | **Vérification autoportée** — Le document se vérifie même si le diplôme n'est pas trouvé au registre (instance partenaire, base indisponible), grâce au sceau signé. | S |

### Module Fingerprinting

Aucun fichier non marqué ne sort de la plateforme : chaque copie, y compris celle du titulaire, porte une empreinte unique.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-FP-01** | **Partager une copie traçable** — Le titulaire génère une copie pour un destinataire (organisation inscrite ou nom libre), une finalité et une durée de validité. | M |
| **BF-FP-02** | **Copie personnelle** — Tout téléchargement par le titulaire produit une copie empreintée à son nom ; l'original non marqué n'est jamais téléchargeable. | M |
| **BF-FP-03** | **Détecter une copie hors contexte** — Si une copie est vérifiée par une organisation qui n'en est pas le destinataire, ou après expiration, la vérification l'indique et le titulaire est alerté. | M |
| **BF-FP-04** | **Gérer ses partages** — Lister, révoquer un partage, consulter l'historique des vérifications de ses copies. | S |

### Module Vérification

La vérification part toujours du **document**, jamais d'une recherche par nom ou numéro, ce qui protège les données des titulaires.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-VER-01** | **Vérification publique** — Déposer un fichier (PDF, PNG, JPEG) et obtenir : établissement émetteur, authenticité, données officielles, statut. | M |
| **BF-VER-02** | **Espace vérificateur** — L'organisation reçoit les copies qui lui sont partagées et vérifie tout document avec contrôle du destinataire. | M |
| **BF-VER-03** | **Rapport de vérification** — Télécharger un rapport PDF signé de la vérification (date, résultat, identifiant de copie). | S |

### Module Administration

L'administration gère la plateforme sans pouvoir toucher aux diplômes ; l'audit est confié à un rôle distinct.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-ADM-01** | **Gérer la plateforme** — Valider établissements et vérificateurs, suspendre des comptes, attribuer les rôles plateforme. | M |
| **BF-ADM-02** | **Gérer les quotas** — Quotas d'émission par établissement et de vérifications par vérificateur. | S |
| **BF-ADM-03** | **Consulter l'audit** — L'auditeur consulte et filtre journaux et alertes, et l'état de la chaîne d'intégrité. | M |

### Module PWA

L'application s'installe sur mobile ; hors ligne, seule l'interface est disponible.

| ID | Fonctionnalité | Prio |
|---|---|---|
| **BF-PWA-01** | **Application installable** — Manifest, icônes, Service Worker ; vérification utilisable sur mobile ; page hors ligne informative. | M |
| **BF-PWA-02** | **Notifications** — Notification dans l'application lors d'une vérification de ses copies ou d'une alerte. | C |

### 6.1 Scénario nominal : de l'émission à la vérification

- L'agent de scolarité de l'établissement saisit les données du diplôme d'Awa et dépose le visuel (PDF) (BF-EMI-01).
- Le directeur des études, connecté avec son second facteur, relit et valide (BF-EMI-02, SR-AUZ-03). La plateforme rastérise le PDF à 300 dpi, insère le filigrane, le sceau caché et produit le certificat signé.
- Awa reçoit une invitation, active son compte et retrouve son diplôme dans son portefeuille (BF-CPT-01).
- Pour une candidature, Awa partage une copie avec l'organisation « Orange CI », finalité « candidature », valable 60 jours (BF-FP-01).
- Le recruteur vérifie la copie depuis son espace : établissement authentique, données officielles affichées à côté du document, copie bien destinée à son organisation (BF-VER-02).
- Si la même copie est présentée plus tard à une autre organisation, la vérification l'indique et Awa est alertée (BF-FP-03, SR-DIM-10).

## 7. Exigences non fonctionnelles (hors sécurité)

| Code | Domaine | Exigence |
|---|---|---|
| **ENF-01** | Performance | Émission d'un diplôme A4 (300 dpi) en moins de 15 s ; vérification en moins de 10 s (serveur 4 vCPU) |
| **ENF-02** | Performance | Écrans de navigation en moins de 500 ms au 95$^{e}$ centile |
| **ENF-03** | Qualité d'image | Marques imperceptibles : PSNR ≥ 40 dB par rapport au visuel déposé |
| **ENF-04** | Robustesse | Marques lisibles après JPEG qualité 75 et redimensionnement à 75 %, grâce à une resynchronisation géométrique avant extraction (seuils validés par prototype au jalon J2) |
| **ENF-05** | Compatibilité | Deux dernières versions de Chrome, Firefox, Edge, Safari ; de 360 px à 1920 px de large ; connexions mobiles lentes (3G) |
| **ENF-06** | Ergonomie | Interface en français ; contraste WCAG 2.1 AA ; verdict compréhensible par un non-spécialiste (couleur + texte) |
| **ENF-07** | Maintenabilité | Couverture de tests ≥ 70 % sur les services métier et 90 % sur le moteur ; API documentée en OpenAPI 3.1 |

## 8. Contraintes techniques et architecture

### 8.1 Socle technique

| Couche | Technologie | Usage dans EburSeal |
|---|---|---|
| **Langage / JVM** | **Java 25** (LTS) | Back-end ; ImageIO ; EdDSA (Ed25519) natif pour signatures et certificats |
| **Serveur d'application** | **WildFly 42** | Déploiement du WAR, Elytron (sécurité, credential store), Undertow (HTTP/TLS) |
| **Plateforme** | **Jakarta EE 11** | REST 4.0 (API), CDI 4.1 (services), Persistence 3.2 + Data 1.0 (dépôts à requêtes paramétrées), Validation 3.1, Security 4.0, Concurrency 3.1, JSON Binding 3.0 |
| **Documents** | Apache PDFBox | Rastérisation des PDF déposés et production des diplômes émis |
| **Cryptographie** | JCA + Bouncy Castle | AES-256-GCM, Argon2id, Ed25519, ES256 (JWT) |
| **Base de données** | PostgreSQL 17 | Registre, partages, clés chiffrées |
| **Client** | SPA React 19 + TypeScript, Vite, vite-plugin-pwa | Espaces titulaire, émetteur, vérificateur ; Service Worker |
| **Intégration continue** | GitHub Actions | Build, tests, SAST, SCA, recherche de secrets |

## 8.2 Architecture cible

L'architecture est en trois couches. Le **moteur EburSeal** concentre la dissimulation ; il s'exécute dans une file de traitement bornée. Les clés ne quittent jamais le serveur.

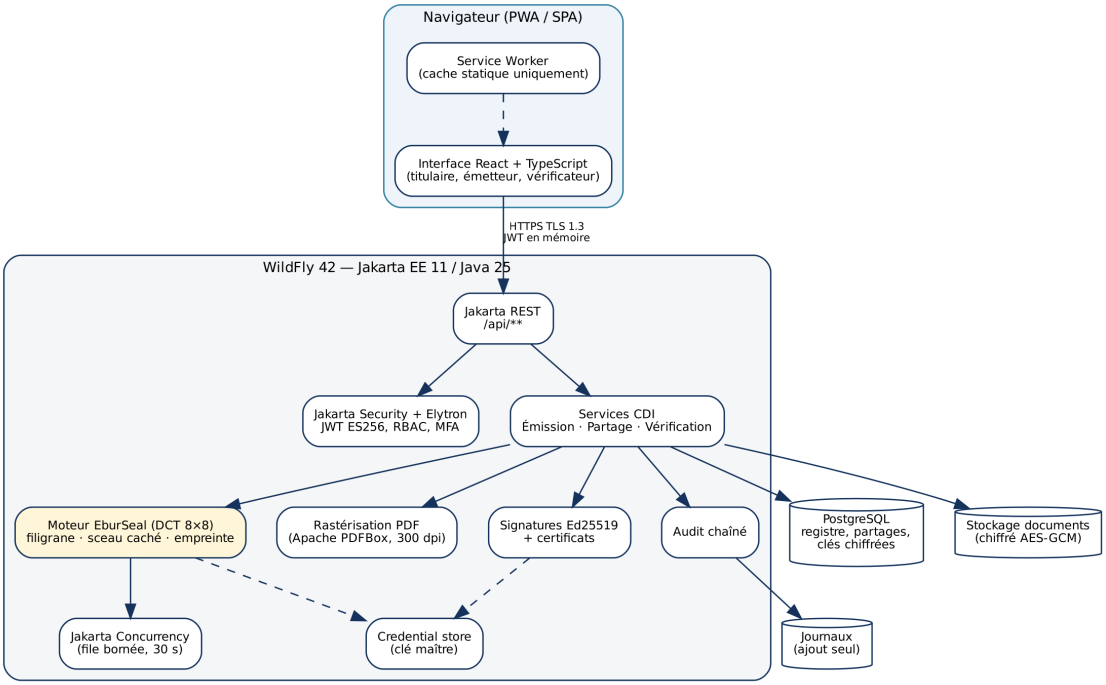



*Figure 1 — Architecture logique d'EburSeal*

## 8.3 Principales ressources de l'API REST

| Ressource | Méthodes | Rôles autorisés | Besoins |
|---|---|---|---|
| **/api/auth/{activate, login, refresh, logout, reset, mfa}** | POST | Public / authentifié | BF-CPT-01 à 04 |
| **/api/institutions, …/{id}/agents** | GET, POST, PUT | Administrateur, Responsable (son établissement) | BF-ETB-01, 02 |
| **/api/diplomas, …/{id}/validate, …/{id}/revoke, /api/batches** | GET, POST | Agent, Responsable (son établissement) | BF-EMI-01 à 04 |
| **/api/wallet, /api/wallet/{id}/copy** | GET | Titulaire (les siens) | BF-FP-02 |
| **/api/shares, /api/shares/{id}** | GET, POST, DELETE | Titulaire (les siens) | BF-FP-01, 04 |
| **/api/verify** | POST | Public (10/h/IP) ou Vérificateur | BF-VER-01, 02 |
| **/api/inbox, /api/reports/{id}** | GET | Vérificateur (son organisation) | BF-VER-02, 03 |
| **/api/admin/**, /api/audit/**** | GET, PUT | Administrateur / Auditeur (MFA) | BF-ADM-01 à 03 |

# 9. Démarche de sécurité et feuille de route

La sécurité suit l'agenda du cours. Toutes les exigences sont spécifiées dès la séance 2 (Shift-Left), puis le code les rejoint chapitre après chapitre.

| Chapitre du cours | Livrable dans EburSeal | Exigences visées |
|---|---|---|
| **Ch. 2 — Spécification & conception** | Cahier des charges, recueil (SQUARE), cas d'abus, arbres d'attaque, STRIDE, squelette du dépôt + test SR-AUZ-01, **prototype du moteur** | Toutes (spécifiées) |
| **Ch. 3 — Confidentialité, intégrité, disponibilité** | Moteur DCT (filigrane, sceau, empreinte), signatures, chiffrement au repos, validation et rastérisation des fichiers, quotas | CON, INT, NRP, DIM, DIS |
| **Ch. 4 — Authentification, autorisation, vie privée** | Comptes, Argon2id, TOTP, JWT, RBAC, double validation, rattachement à l'établissement, minimisation | AUT, AUZ, PRV |
| **Ch. 5 — Journalisation & erreurs** | Journal d'audit chaîné, alertes de volume, ExceptionMapper RFC 9457 | LOG, ERR |
| **Ch. 6 — Tests de sécurité** | SAST, SCA, DAST (ZAP), tests d'abus, banc de robustesse | TST |
| **Ch. 7 — Déploiement & maintenance** | WildFly durci, conteneurs non root, en-têtes, sauvegardes, rotation des clés | DEP, DIS-04 |

> **Évolution** — le recueil des besoins est versionné et mis à jour à chaque séance (phase de **gestion des exigences**). Toute évolution passe par une issue GitHub et une pull request relue.

# 10. Organisation, livrables et planning

## 10.1 Organisation du dépôt GitHub

| Élément | Convention |
|---|---|
| **Visibilité** | Dépôt **privé**, accès accordé à l'encadrant ; tous droits réservés aux auteurs |
| **Arborescence** | backend/ (WAR Jakarta EE 11) · frontend/ (PWA) · docs/ (PDF + sources) · .github/ (CI, modèles d'issues et de PR) |
| **Branches** | **main** protégée (release, tag par séance) · **develop** (intégration) · feature/<id-besoin>-<description> |
| **Pull requests** | Relecture obligatoire par l'autre membre ; liste de contrôle sécurité ; CI verte obligatoire |
| **Backlog** | Issues **feature** (BF-…), **abuse-story** (CA-…), **security-story** (SR-…), étiquetées par chapitre (ch2 … ch7) |
| **Traçabilité** | Chaque commit et PR citent l'identifiant du besoin (ex. « SR-AUZ-03 : double validation de l'émission ») |

## 10.2 Livrables

| Livrable | Emplacement | Échéance |
|---|---|---|
| **Cahier des charges (ce document)** | docs/cahier-des-charges.pdf | Séance 2 |
| **Recueil des besoins fonctionnels et SRE** | docs/recueil-des-besoins.pdf | Séance 2, mis à jour à chaque séance |
| **Référentiel des exigences (CSV)** | docs/exigences.csv | Séance 2, mis à jour en continu |
| **Rapport du prototype du moteur (PSNR, robustesse)** | docs/rapports/prototype-moteur.pdf | Séance 3 |
| **Code source + pipeline CI** | backend/, frontend/, .github/ | Incrémental, séances 3 à 7 |
| **Rapports de tests de sécurité** | docs/rapports/ | Séance 6 |

### 10.3 Planning prévisionnel

| Jalon | Contenu | Critère de passage (« gate ») |
|---|---|---|
| **J1 — Séance 2** | Spécification & conception, squelette du dépôt | Documents dans docs/ ; CI verte ; déploiement WildFly 42 du squelette |
| **J2 — Séance 3** | Prototype du moteur + intégrité / confidentialité | PSNR ≥ 40 dB et marques lisibles après JPEG Q75 ; exigences INT/CON P1 testées |
| **J3 — Séance 4** | Comptes, MFA, RBAC, double validation ; émission | Exigences AUT/AUZ P1 testées ; tests IDOR et auto-validation verts |
| **J4 — Séance 5** | Audit, alertes, erreurs ; partages et fingerprinting | Chaîne d'audit vérifiée ; détection « hors contexte » démontrée |
| **J5 — Séance 6** | Campagne de tests de sécurité | 0 alerte haute SAST/SCA/ZAP ; 11/11 cas d'abus couverts |
| **J6 — Séance 7** | Déploiement durci, démonstration | Checklist DEP validée ; restauration testée |

## 11. Critères d'acceptation et « Definition of Done »

Une fonctionnalité est considérée comme **terminée** seulement si :

- ses critères d'acceptation (recueil, § 3) sont vérifiés par un test automatisé ;
- ses cas d'abus ont été rédigés **avant** le développement, et chacun est couvert par un test qui démontre l'échec de l'attaque (SR-TST-04) ;
- les exigences de sécurité qu'elle touche sont implémentées et vérifiées selon la méthode prévue ;
- la CI est verte : build, tests, SAST sans alerte haute, SCA sans CVSS ≥ 7, aucun secret détecté ;
- la pull request a été relue et approuvée par l'autre membre, et la matrice de traçabilité est à jour.

### 11.1 Risques projet

| Risque projet | Impact | Parade |
|---|---|---|
| **Robustesse des marques DCT insuffisante après recompression** | OM-2 partiellement atteint | Prototype dès J2 sur un banc de 50 diplômes ; resynchronisation géométrique (réalignement sur la grille 8×8) ; redondance et code correcteur ajustables |
| **Capacité insuffisante pour trois couches sur un A4** | Sceau tronqué | Rastérisation à 300 dpi (≈ 136 000 blocs) ; sceau compact (≈ 250 octets) |
| **Charge de travail (sécurité identique à un trinôme)** | Retard | Priorisation AHP : P1 d'abord ; besoins « Could » abandonnables |
| **Évolution des exigences au fil du cours** | Incohérences documentaires | Référentiel unique (data.py → PDF + CSV) régénéré à chaque évolution |